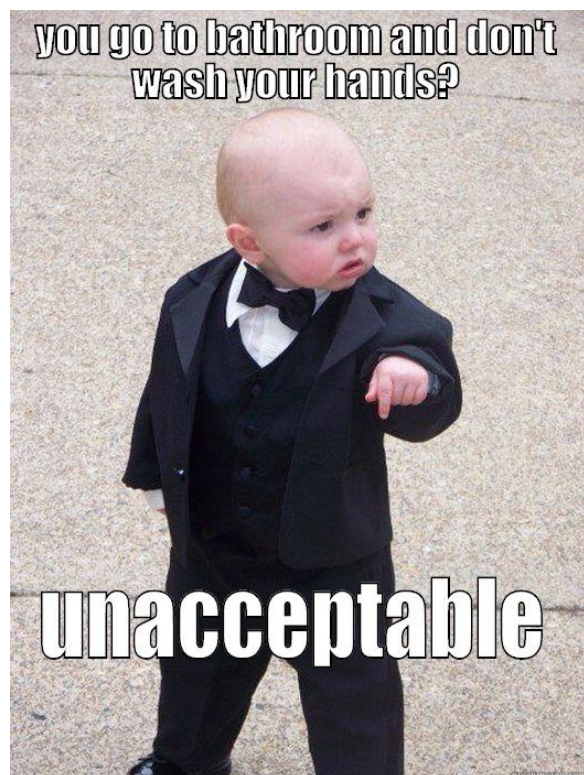


Passkeys & Password Managers

OLLI Digital Explorers SIG

David Shamlin September 2026

My main objectives with this talk & handout are



- To explain what happens “under the covers” when you create & use passkeys
- To describe how you use an authenticator app with two-factor authentication (2FA)
- To show you examples of passkeys and authenticator apps “in action”

Note: I’m going to do the showing using screenshots I made when I stepped through various scenarios before this meeting. I put those screenshots in a separate handout (that can be accessed from the DESIG site schedule page; that handout is named “Demo” on the schedule page.)

- To share how I vet an app before I install it—specifically today, a password manager app.

Authentication

Signing in to an account

- Authentication is the process of **verifying a user's or system's identity**. It ensures that an individual or entity is who they claim to be before granting access to a system or data. Authentication is crucial for **safeguarding sensitive information** and **maintaining the integrity** of online services.
- Authentication is a cornerstone of digital security, serving as the **first line of defense** against unauthorized access to sensitive information and systems.
- Authentication serves several key purposes:
 1. **Security**: By verifying identities, authentication prevents unauthorized access to systems and data.
 2. **Trust**: Secure authentication processes build trust between users and service providers.
 3. **Efficiency**: Streamlined authentication processes can enhance user experience and operational efficiency.

Authentication Factors

- An authentication factor is a piece of information that is used to verify/validate that you—the person signing in to a site—are indeed the same person that created (and therefore is said to “own”) the account you that you are signing in to.
- Factors fall into three categories:
 - Something you *know* (aka, a knowledge factor)

User ids and passwords fall into this category. PINs are also an example of this type of factor.

- Something you *have* (aka, a possession factor)

The 6-digit code you receive via text/email when you have 2FA enabled for an account is an example of this type of factor. When a 6-digit code is sent to you via text, you have to have the phone the code was sent to in your possession in order to use it; when a code is sent to you via email, you have to be in possession of the inbox associated that email address.

- Something you *are* (aka, an inherence factor)

This factor depends on biometric identification. I.e., fingerprint and/or facial recognition.

The term “**credentials**” is a synonym of the word “factors”.

One-Time Passcodes (OTP)

- The six-digit codes used with when two-factor authentication is enabled for an account are called **one-time passcodes (OTP)** “geek speak.”
- These codes are only valid for one use. I.e., if a hacker managed to “steal” from an email or text that contained a code, it will only help them break into my account if they are able to use it before I do.
- These codes usually have “expiration dates.” They have to be used within a certain period of time from the moment they were generated. E.g., you may have seen statements like “This code is only good for n minutes from the time this email/text was sent” in email/text messages you receive with these codes or on the sign-in page of the site you are signing in to. Note that if/when you don’t see statements like that, that doesn’t mean the code has no “expiration date”; it just means the site you are signing in to isn’t telling you. The standard industry practice for is to always and only generating codes with “expiration dates” when they are being used to sign-in to accounts.
- The expiration time periods for codes sent via email/text can vary between sites but it is usually for some period of minutes. OTPs that have “expiration dates” are called **time-based one-time passcodes (TOTP)** in “geek speak”.
- 10-15 minutes seems to be typical in my experience although I have seen some set to periods between 90 minutes and a couple hours.
- The expiration of codes generated by authenticator apps are good for some number of seconds. Industry standard/best practice recommendations are for them to be created with 30, 60, or 90 second expiration periods. The authenticator apps I am familiar with all use 30 seconds.

Methods of Authentication

1. Basic (a.k.a. single-factor) authentication

When you sign in using an id (e.g., user name, email address) and a password. The id and password together count as one factor (hence the term “single-factor”).

2. Two-Factor authentication (2FA)

*When you must enter a **TOPT** in addition to your id and password. The id and password is one factor; the OTP is a second factor.*

3. Multi-Factor (MFA) authentication

When you must enter one or more pieces of information in addition to an id, password, and OTP. For us, the “one more piece” will be security questions. There are some additional kinds of factors that are used by businesses, government agencies—including the military—that deal with classified/top secret documents, and need to very tightly control who inside those organizations are allowed to access that type of information.

Note: The terms/acronyms *two-factor authentication (2FA)* and *multi-factor authentication (MFA)* are sometimes treated as synonyms. I have also seen them used ambiguously. E.g., I have seen 2FA used to refer signing in using passcodes sent via email/text and MFA to refer to signing in using passcodes generated via an authenticator app.

4. Passkeys

A method of verifying an app or website user who is tied to both the app or site and the device trying to gain access. Both “keys” need to fit before a user is allowed in, but the process is done without entering a username or other proof of identification.

5. Social Sign-In

A method that lets you log in to a site using using your social accounts on platforms like Google, Apple, Facebook, or LinkedIn. The primary benefit of this “flavor” is ease of use. The primary cons are (1) reduced privacy and (2) slightly reduced security protection (i.e., if a hacker is able to hack into the account you sign in using, they can also access to the account you are signing in to.

Relative strengths of Authentication Methods

- Each of these methods provide a different amount of protection.
- The difference in the amount or protection provided by these two methods is relatively small, and there are differing opinions within the cybersecurity community on which one is stronger.
- Some tech journalists describe passkeys as “impenetrable.” Based on my understanding of passkeys, I agree they provide a level of protection that is far greater than the other methods and I also won’t be terribly surprised when the day comes that some company experienced a security/data breach where hackers exploited a passkey.

Basic	id & password
2FA via Email	id & password + OTP
2FA via Text	id & password + OTP
2FA via Authenticator App	id & password + OTP
Passkey	Contains two factors: id & password + OTP

The degree of protection you have when signing in to an account social sign-in is the same as the degree of protection you have with the account you use to sign in with.

Weaker



Stronger

Should I regularly change my passwords?

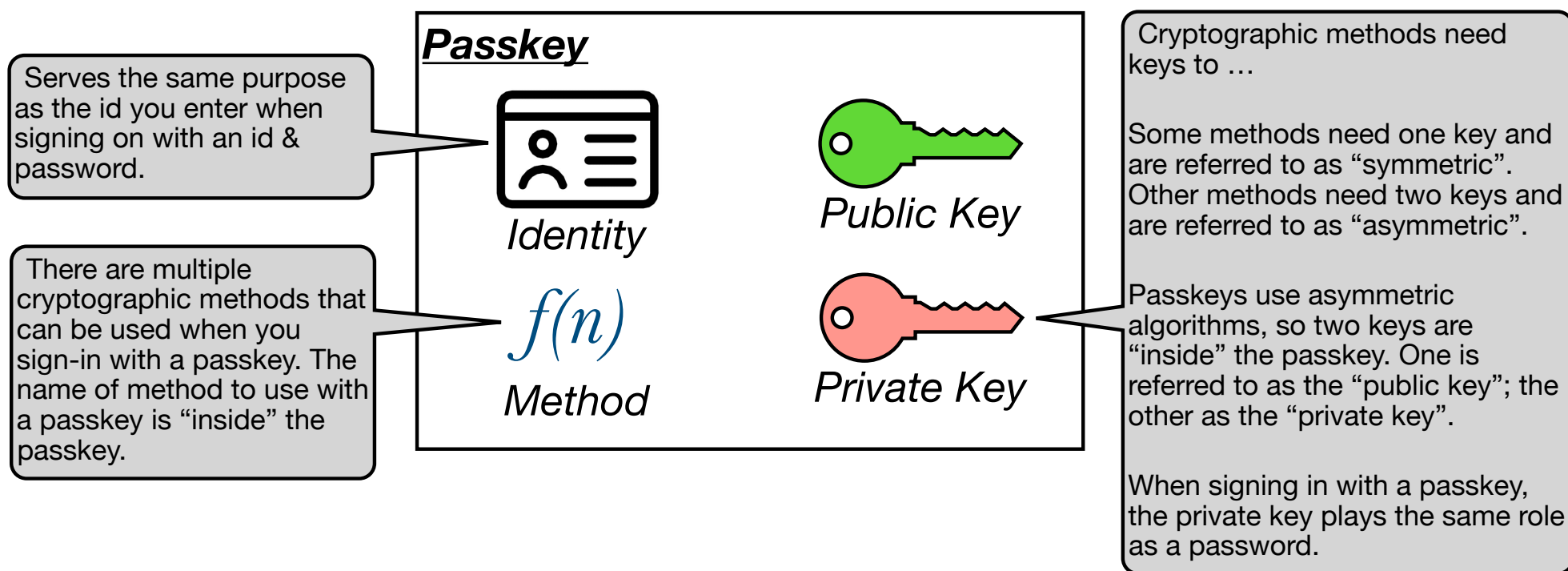
By the early 2000s, most businesses had policies that required employees to regularly change their policies. Making employees change their passwords every 30, 60, or 90 days was common. Around that same time, processor speeds increased greatly (making it easier for hackers to “crack” passwords) and researchers started reporting the results of studies that indicated forcing people to change their passwords on such short intervals resulted in adverse affects; i.e., the number of weak and reused passwords increased. Consequently, businesses started changing their cybersecurity practices; policies that forced employees to change passwords on a consistent basis were replaced by policies requiring all employees to use 2FA via authenticator apps, assure their passwords were strong, and only change passwords in certain situations. Those new practices/policies continue to be industry standard today and are equally useful outside of business contexts.

When to consider changing your passwords:

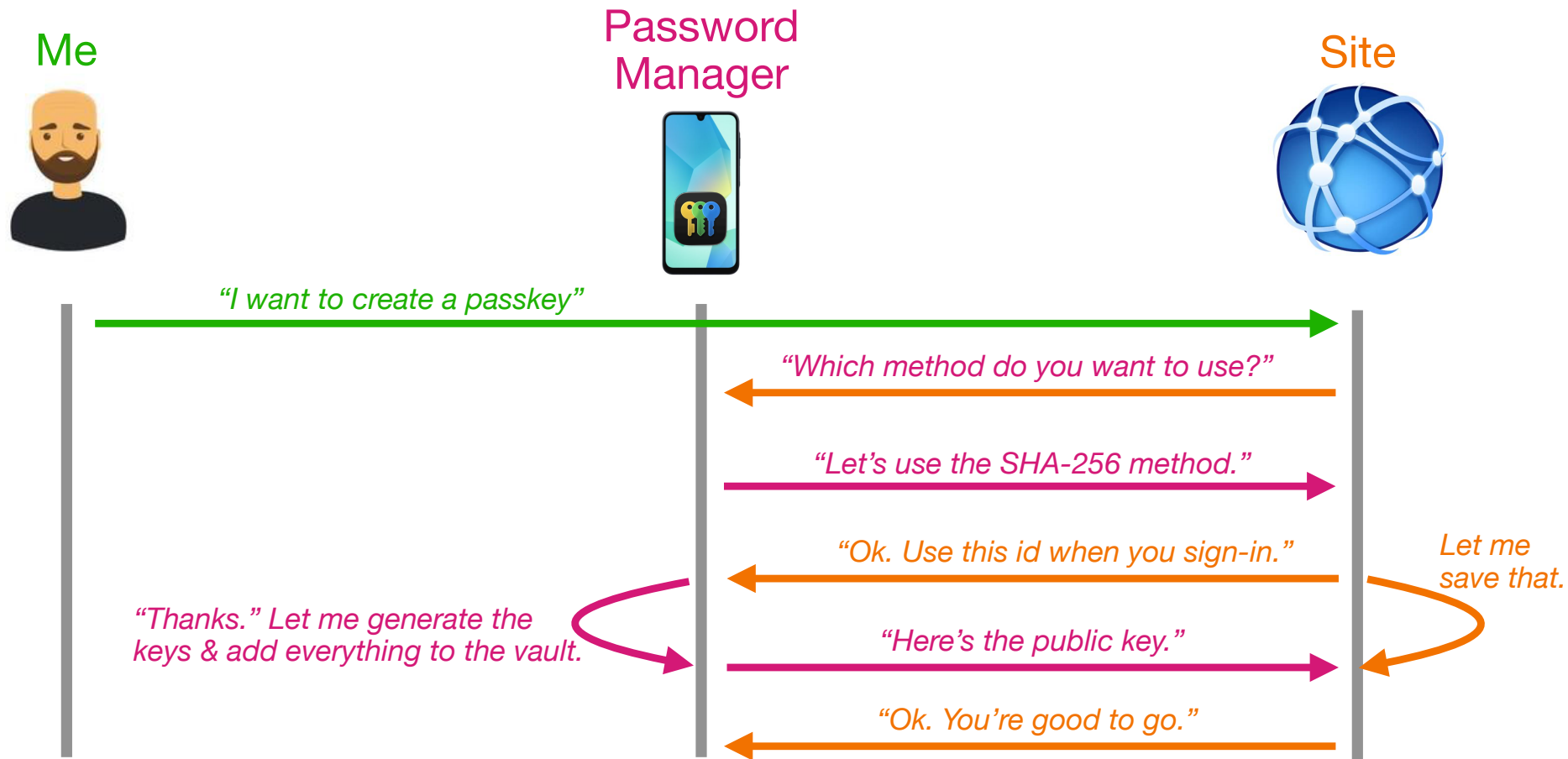
- The associated site has been hacked
- You suspect someone has tried to access your account or device
- You shared a password with someone and they are done using your account
- You realize a password is weak or reused
- You think your device might have a virus—or some other form of malware
- You click on a link in an email or text that looks like a scam/phishing attempt

Passkeys

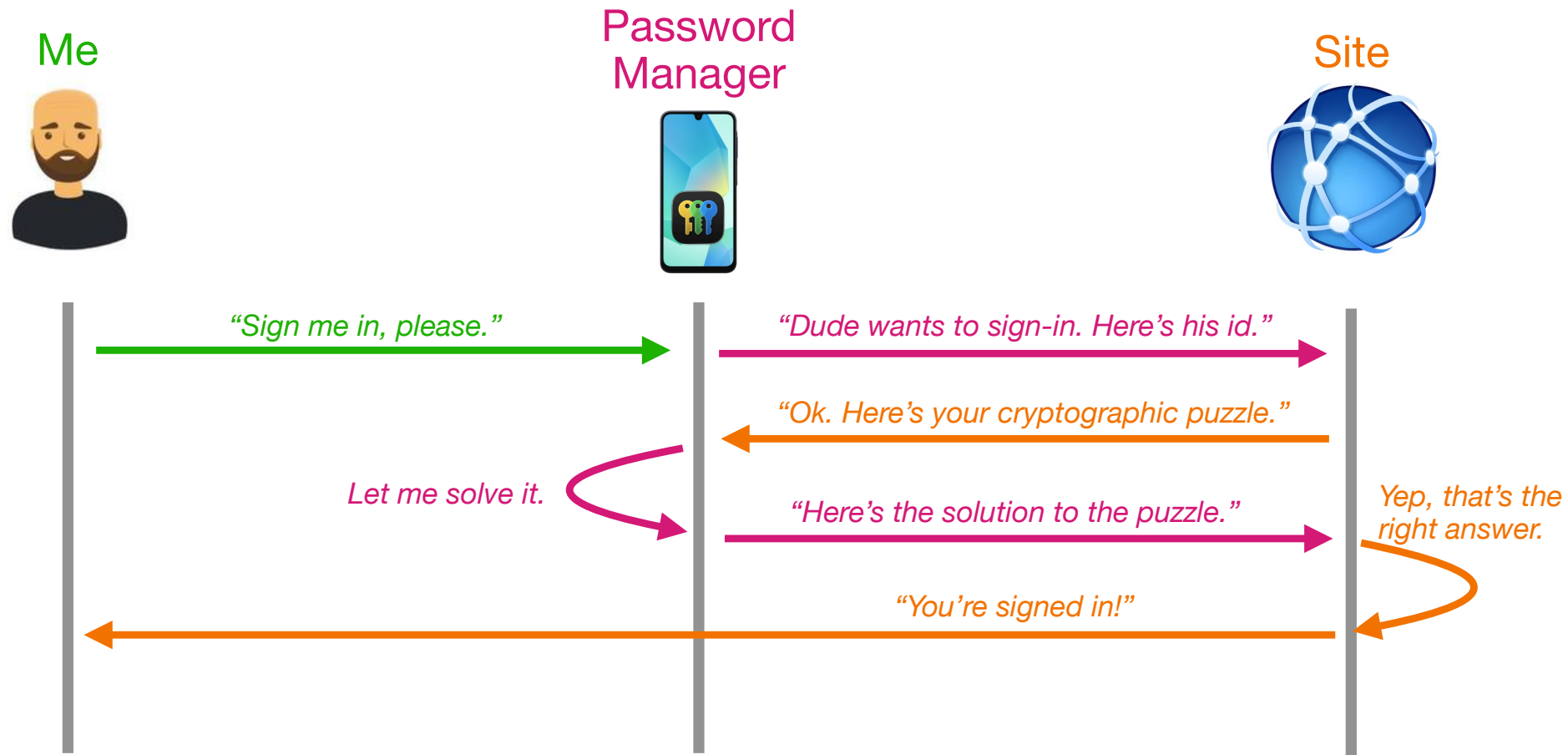
“A passkey is an authentication credential that uses asymmetric cryptography.”



What happens when I set up an account to use a passkey



What happens when I sign in with a passkey



What is a password manager?

- A password manager is software that securely stores and manages login credentials in an encrypted vault, protected by a single master password.
- It eliminates the need to remember multiple passwords while helping generate strong, unique passwords for each account, reducing the risk of breaches.
- Password managers can automatically fill in login details, save time, and often sync across devices for convenient access anywhere.
- They provide added security benefits, such as warning against phishing sites and limiting damage from compromised accounts by encouraging unique passwords.
- While generally safe and effective, they still require good security practices like protecting the master password, using multi-factor authentication, and keeping devices free from malware.

— [malwarebytes.com: What is a password manager](https://malwarebytes.com/What-is-a-password-manager)

“Flavors” of password managers

1. Stand alone apps

Password managers in this category tend to have the most features people need/prefer and provide the greatest flexibility in terms day-to-day use.

All of the password managers found in the survey section are of this flavor.

2. Built in to browsers
3. Browser extensions

Password managers in these two categories tend to have fewer features and less flexibility in terms of day-to-day use.

Browser extensions are attractive targets for hackers who spread malware. Be very cautious if/when considering installing and using browser extensions.

Common Password Manager Features

Must Have	Nice to Have
• Industry standard/“leading edge” cybersecurity protection • File encryption (aka, data-at-rest) • Encrypted communication over the Internet (aka, data-in-motion) • Zero-knowledge security • Passkey support • Password generator • Ideally with controls that allow you to control the length of the generated passwords and the kinds of characters included in generated passwords • Save	• Multi-platform support (i.e., the software can be installed/used on all of your devices) • Interoperability with your browser(s) & apps (that involve signing to an account) • Autofill • Sync • Import/export
	• Stores more than sign in credentials (e.g., user name, passwords) • Organizational: folders, tags • Secure sharing of credentials • Authenticator app • Audits, breach monitoring, and alerts
	• Emergency access • Backup
<i>I think this set of features has become close to “industry standard.” I.e., I don’t remember the last password manager I took a serious look at that did <u>not</u> have these features.</i> <i>Some password managers do better with autofill than others. (In my opinion, the Apple Passwords app does an exceptionally good with autofill.)</i>	<i>I find these features very convenient, but I would not reject a password manager if it didn’t have these features. Sharing credentials may be an exception for some. If you share any of your accounts with family/friends, using 2FA/MFA or passkeys with those accounts can make sharing more challenging.</i> <i>These are new to me in the context of password managers. I’m not sure I would use “emergency access”; vendors saying their password manager supports “backup” are putting a “marketing spin” on the sync feature.</i>

My guidelines when deciding to install an app

Primary Considerations

The questions I ask myself when considering installing an app focus on three qualities of software:

- **Quality**

Will I get the value I want/need from it for a cost I'm willing/able to pay?

- **Security**

Will installing it compromise the level of cybersecurity I need?

- **Privacy**

Will it maintain the degree of privacy I want?

Specific Questions

1. Does the app have the features that I want/need?
2. How frequently is the app being updated?

This information is easy to find in Apple's App Store. I am less likely to install an app if the seller of the app isn't updating it at least twice a year.

3. Who made the app?

1. If I'm not familiar with the company, I search for and spend some time perusing its website. Does the website have a modern aesthetic? Is there an "about us" page

4. What is the cost to install/use this app? I.e.,

1. If the app has "in-app purchases", are there subscription fees or one time cost needed to "unlock" some features?
 2. If the app is "free", I look more closely at privacy and security considerations. *Nothing in life is free, and "free" apps often have adds and (often aggressively IMO) collect data the company profits from in other ways.*

5. Do I have to have an online account to use the app? If I have to be signed into an account I create on the seller's website to use the app, then I'll have another account to manage and the seller may be collecting data on me and that may make me less likely to install the app.
6. How have others reviewing/rated the app? In addition to reviews/ratings you find in app stores, tech industry analysts/journalists sometime publish reviews on the Internet; search queries like "reviews of app-name device-type-name app" (e.g., "reviews of merlin bird id iphone app"; including "iPhone app", "Mac app" or "iPad app" in the search query often results in much better search results.)
7. That Apple App Store has an "App Privacy" section on each's apps page. If that section indicates the app does collect data, I then look at the seller's privacy statement.

Most Commonly Recommended

By Tech Industry Analysts in 2025-2026

There are quite a few (approx 2-3 dozen) reputable/trustworthy password manager apps on the market. Tech industry analysts/journalist tend to publish annual comparative reviews of these apps.

I found 17 such reviews published in 2025 and 2026. Recommended a password manager app; the box to the left lists the seven most frequently recommended password managers. The number beside each password manager's name is the number of reviews that recommended that password manager.

The comparative reviews are all available on the Internet. Links to each of them can be found on the DESIG site's [references page](#).

-  [1Password](#) (16)
-  [Nordpass](#) (14)
-  [Dashlane](#) (13)
-  [Proton Pass](#) (12)
-  [Keeper](#) (12)
-  [BitWarden](#) (11)
-  [RoboForm](#) (10)



Apple Passwords & Keychain Apps



- Apple announced they were adding a password manager app (named “Passwords”) to their operating systems in September 2024; it was included in operating system updates Apple made available the same month.
- The Passwords app has all the features listed in the “Must Have” column on the previous page. It also has the following features:
 - Multi-platform support (i.e., the software can be installed/used on all of your devices)
 - Interoperability with your browser(s) & apps (that involve signing to an account)
 - Autofill
 - Sync
 - Import/export
 - Secure sharing of credentials
 - Authenticator app
 - Audits, breach monitoring, and alerts
- Another app—named “Keychain”—that is included with Apple operating system is used by The Passwords app. The Passwords app delegates to Keychain to perform its synch and encryption features.
- The Passwords app’s autofill feature is very sophisticated. In my experience using it, it performs autofills so quickly and seamlessly I barely notice it happening.
- The Passwords app’s “secure sharing of credentials” feature has a noteworthy limitation: You can only share credentials with others who also use Apple devices.
- There are a couple of additional steps. you may need to take before you can share credentials with others:
 - The person(s) you want to share credentials with must be in your Contacts app with the email address they use for iCloud and you must be in the other person’s Contact app with the email address you user for iCloud.
 - Keychain has to be configured to use iCloud.

See the “Share Passwords” section in Apple’s [Passwords User Guide](#) for more details.